NOTE DE SÉCURITÉ

Équipe	**Kadem**		
Université	[Université]		
Membre	**Nom et prénom**	**Filière et niveau**	**Contact (e-mail, téléphone)**
Membre 1	[Nom Prénom]	[Filière – Niveau]	[e-mail – téléphone]
Membre 2	[Nom Prénom]	[Filière – Niveau]	[e-mail – téléphone]

1. Actifs à protéger et hypothèses de confiance

Actifs : contenu des messages et des fichiers (secret professionnel) ; identité des agents (nom, ministère, fonction) ; métadonnées (qui échange avec qui, quand, tailles). **Hypothèses :** le serveur est « honnête mais curieux » (il ne doit jamais lire le contenu, il voit des métadonnées ; sa compromission est traitée en section 2) ; l'administrateur est de bonne foi ; les clés privées restent sur l'appareil et ne sont jamais transmises ; le client web servi est authentique (limite en section 5).

2. Menaces prises en compte

Menace et scénario	Protection mise en place	Limite résiduelle
Écoute réseau : interception du trafic	TLS 1.2/1.3 + chiffrement de bout en bout (Olm / Megolm)	Métadonnées de trafic (tailles, horaires)
Serveur compromis : lecture de la base ou des fichiers	Le serveur ne détient que du texte chiffré ; clés privées sur les appareils	Métadonnées ; ajout d'un appareil malveillant (vérification d'empreinte possible)
Vol de compte : mot de passe deviné ou volé	Argon2id + TOTP + anti-rejeu du code + verrouillage 15 min après 5 échecs	Vol simultané du téléphone TOTP
Appareil perdu ou volé	Révocation immédiate (compte Synapse désactivé, retrait des salons, rotation des clés de groupe) ; effacement local des clés à la détection	Messages déjà déchiffrés avant révocation lisibles sur l'appareil s'il reste hors ligne
Intrus non enrôlé : inscription ou connexion	Inscription publique désactivée ; Nginx bloque les routes Matrix directes ; seule la passerelle est accessible	Une erreur de règle au proxy rouvrirait la route (défense en profondeur)
Contournement de la passerelle : appel direct à /login ou /_synapse/admin	Routes bloquées pour toutes les versions de chemin ; test automatisé avant mise en service	Idem : dépend de la règle du proxy
Fuite par un destinataire : capture d'écran, copie	Classification « Confidentiel » : bannière, filigrane, blocage de la copie, expiration	Photographie de l'écran non évitable
Injection dans le client : script dans un message	CSP stricte, échappement systématique, aucun HTML brut injecté	Faille inconnue d'une dépendance
Falsification de l'audit : effacement de traces	Journal chaîné par empreintes SHA-256 : toute modification est détectée	Accès physique de l'administrateur de base de données (détection, non prévention)

3. Protections mises en place

- **Chiffrement :** en transit TLS 1.2/1.3 et WSS ; contenu en bout en bout (Matrix Olm / Megolm, vodozemac), aucune cryptographie maison ; au repos : mots de passe Argon2id, secrets TOTP et mots de passe Matrix chiffrés (Fernet).
- **Authentification :** inscription publique désactivée, enrôlement par un administrateur, mot de passe de 12 caractères minimum + TOTP (RFC 6238) ; anti-énumération : tous les échecs renvoient le même 401 et le même message, avec calcul Argon2id factice pour les comptes inconnus.
- **Révocation :** statut « révoqué » et audit, désactivation du compte Synapse (jetons invalidés), retrait des salons (rotation des clés Megolm par les clients des autres membres), suppression des appareils ; en cas d'échec d'une étape, la révocation est marquée incomplète, réessayable, et la connexion reste refusée.
- **Audit :** entrées chaînées par SHA-256, écriture sérialisée sous transaction ; aucun mot de passe ni code n'y figure.
- **Infrastructure :** seul le port 443 est exposé ; fédération et présence désactivées ; deux bases PostgreSQL séparées ; conteneurs non-root ; versions figées et auditées (pip-audit, npm audit) ; aucun secret dans Git.

Innovation et sécurité : le mode « Confidentiel » n'est pas qu'une étiquette. Il applique des règles de sécurité côté client (bannière, filigrane, blocage de la copie, expiration) qui réduisent le risque de fuite par un destinataire. L'étiquette elle-même est incluse dans le contenu chiffré, donc le serveur ne sait pas quels messages sont classifiés. C'est une innovation qui renforce la sécurité sans compromettre la confidentialité.

4. Métadonnées visibles par le serveur et mesures de réduction

Information visible (pourquoi)	Mesure de réduction	Reste exposé ?
Identité des comptes (annuaire, contrôle d'accès)	Identifiants Matrix pseudonymisés ; détails dans la passerelle seule	Oui, par l'administrateur
Appartenance aux conversations (routage)	Aucune réduction possible sans changer de modèle	Oui : limite connue
Date et heure des messages (ordre, acheminement)	Aucune réduction possible	Oui : limite connue
Taille des messages et fichiers (stockage)	Limite de taille ; remplissage non prévu	Oui : limite connue
Adresses IP (connexion réseau)	Journaux du proxy sans adresses ; conservation réduite dans Synapse	Réduit
Présence et frappe en cours	Désactivées	Non
Contenu, noms de fichiers, niveau de classification	Dans le contenu chiffré	Non
Noms, descriptions et membres des groupes (état des salons non chiffré)	Noms de groupes neutres, aucune donnée sensible dedans	Oui : limite connue
Clés publiques des appareils (sessions chiffrées)	Vérification d'empreinte par les agents	Oui : par nature publiques

5. Limites connues

- **Capture d'écran :** un navigateur ne peut pas l'empêcher de façon fiable. Les mesures du mode « Confidentiel » (filigrane, blocage de la copie, expiration) sont dissuasives et traçantes, non absolues, et ne s'appliquent que dans notre client.
- **Messages déjà déchiffrés :** avant une révocation, ils restent lisibles sur l'appareil tant que ses données locales ne sont pas effacées ; l'effacement local ne fonctionne que si l'appareil se reconnecte.
- **Métadonnées :** appartenance aux conversations, dates et tailles restent visibles du serveur (voir section 4).
- **Client servi altéré :** un attaquant maîtrisant le serveur pourrait servir un client web modifié aux agents ; piste d'amélioration : publier une empreinte du client.
- **Stockage local et historique :** les clés sont dans IndexedDB, non chiffré au repos par le navigateur ; sans sauvegarde de clés, un nouvel appareil ne lit pas l'historique. La passerelle conserve un mot de passe Matrix chiffré par agent : sa compromission permettrait d'ouvrir une session au nom d'un agent (sans lire l'historique), d'où l'intérêt de la vérification d'appareil.
- **Dépendances et déni de service :** une faille inconnue d'une dépendance reste possible ; un déni de service distribué est hors du périmètre du prototype.

Conclusion : le serveur ne lit jamais les messages, toute modification de l'audit est détectable et les limites restantes sont documentées. Aucune cryptographie n'est développée par l'équipe.